

Module 20

Kerberos & Active Directory Attack Paths

Dari ticket flow ke relationship graph: SPN, delegation, ACL, trusts, AD CS, BloodHound reasoning, controlled validation, telemetry, dan evidence discipline.

Learning path module ini

Kerberos flow -> SPN/service identities -> delegation -> ACL relationships -> trusts -> AD CS -> BloodHound path reasoning -> controlled validation -> detection-aware reporting.

Exit criteria

- Bisa menjelaskan TGT, service ticket, KDC, SPN, PAC, dan hubungan authentication vs authorization tanpa menghafal tool output.
- Bisa mengidentifikasi kandidat attack path dari service account, delegation, ACL, trust, dan certificate template secara read-only.
- Bisa membedakan relationship evidence dari exploitability: sebuah BloodHound edge bukan bukti bahwa path pasti dapat dieksekusi.
- Bisa membuat hipotesis, precondition, impact, telemetry, dan remediation sebelum melakukan controlled validation pada lab yang authorized.

Authorized-lab rule Semua hands-on memakai synthetic dataset, read-only inventory, GOAD/MINILAB yang terisolasi, atau platform training yang secara eksplisit mengizinkan teknik ofensif. Jangan mencoba ticket extraction, credential attacks, delegation abuse, ACL modification, atau certificate abuse pada domain pihak lain.

1. Mental Model: Identity -> Ticket -> Relationship -> Path

AD attack path bukan daftar command. Sebuah path adalah rangkaian hubungan yang, bila semua precondition benar, dapat mengubah kontrol dari principal awal menuju objective yang lebih sensitif. Karena itu setiap edge harus dijawab dengan lima pertanyaan: siapa principal-nya, object mana yang dikontrol, permission apa yang membuat hubungan itu relevan, precondition apa yang diperlukan, dan telemetry apa yang akan muncul.

Layer	Pertanyaan utama	Contoh evidence
Identity	Siapa principal yang sedang kita punya?	SID, group membership, token
Authentication	Bagaimana principal membuktikan identitas?	TGT, service ticket, certificate
Authorization	Apa yang boleh dilakukan principal?	ACL, group, local admin, GPO
Relationship	Object mana yang dipengaruhi?	SPN owner, delegation target, trust
Path	Apakah beberapa relationship dapat dirangkai?	BloodHound / graph hypothesis

Lab 01 - Workspace & scope

```
./labs/workspace-init.sh module20-ad-paths
# isi 00-scope/README.txt dengan domain lab, permitted hosts, testing window, dan stop conditions
```

2. Kerberos: Ticket Flow yang Harus Benar-benar Dipahami

Dalam AD DS, KDC berjalan pada domain controller dan menggunakan database AD sebagai security account database. Client pertama-tama mendapatkan Ticket Granting Ticket (TGT), lalu memakai TGT itu untuk meminta service ticket untuk SPN tertentu. Server memvalidasi service ticket dan dapat memakai authorization data di PAC untuk membuat access decision.

```
User/Computer
| AS-REQ / AS-REP
v
KDC (DC) ----> TGT
^
|
| TGS-REQ | request service ticket for SPN
+-----+
| TGS-REP
v
Service Ticket -> Target Service
```

Key distinction TGT membuktikan bahwa principal sudah diautentikasi ke KDC. Service ticket membuktikan permintaan akses ke service tertentu. Keduanya tidak otomatis berarti caller memiliki authorization terhadap resource aplikasi.

Apa yang perlu dibaca dari sebuah ticket

Field / concept	Kenapa penting
Client principal	identitas yang ticket-nya mewakili
Server principal / SPN	service mana yang menjadi audience ticket
Validity window	membantu memahami lifetime, renewal, dan stale evidence
Encryption type	menunjukkan crypto yang benar-benar dinegosiasikan/dipakai
Ticket flags	forwardable/renewable/delegation semantics tertentu
PAC / authorization data	membawa authorization context yang dipakai Windows services

Kerberos troubleshooting sebelum membuat attack hypothesis

Symptom	Kemungkinan penyebab	Check
Kerberos gagal dan NTLM muncul	SPN/DNS/service-name mismatch	DNS, SPN registration, target name
KRB_AP_ERR_SKEW / auth intermittent	clock skew	client/DC time + NTP hierarchy
KDC_ERR_ETYPE_NOTSUPP	encryption-type mismatch	account/domain crypto policy
service ticket salah audience	duplicate/missing SPN	setspn query/read-only inventory

Lab 02 - Inspect ticket cache, bukan membuat ticket baru

```
PowerShell> .\labs\ticket-cache.ps1
```

```
PowerShell> klist
```

- Catat client principal, service name/SPN, encryption type, start/end time, dan ticket flags yang terlihat.
- Jangan purge ticket atau inject ticket pada module fundamental ini; objective-nya memahami state normal terlebih dahulu.

3. SPN dan Service Account Attack-Path Reasoning

Service Principal Name (SPN) adalah identifier unik service instance yang menghubungkan service dengan account yang menjalankannya. Dari perspektif assessment, SPN membantu memetakan service identities. Risiko meningkat ketika service identity memakai password lama, encryption legacy, privilege tinggi, atau lifecycle yang lemah.

Read-only live inventory (authorized domain)

```
Get-ADUser -LDAPFilter '(servicePrincipalName=*)' `
-Properties servicePrincipalName,PasswordLastSet,msDS-SupportedEncryptionTypes,MemberOf `
| Select-Object SamAccountName,PasswordLastSet,msDS-SupportedEncryptionTypes,servicePrincipalName,MemberOf `
| Export-Csv -NoTypeInformation .\module20-ad-paths\02-spn\spns.csv
```

Lab 03 - Synthetic SPN risk review

```
python .\labs\spn-risk-review.py .\labs\sample-spns.csv --output module20-ad-paths\02-spn\spn-review.json
```

Script hanya membuat prioritization candidates. Score tinggi bukan bukti account dapat dikompromikan.

Roastability concept Kerberoasting dan AS-REP roasting penting untuk dipahami sebagai kondisi yang memungkinkan material autentikasi diverifikasi secara offline. Di module ini kita tidak mengajarkan ticket extraction terhadap domain nyata. Actual extraction/cracking hanya dilakukan di deliberately vulnerable lab yang authorized dan memakai credential fixture/training.

Signal	Kenapa relevan	Bukan berarti
User-backed SPN	service key terkait password user account	password pasti lemah
Password age tinggi	rotation mungkin lemah	hash pasti crackable
RC4/legacy crypto	legacy exposure / hardening gap	langsung exploitable
Privilege tinggi	impact lebih besar bila identity hilang	path sudah terbukti

Service-account lifecycle matters

Akun service tradisional sering punya password rotation yang lebih lambat karena takut merusak dependency. gMSA dirancang agar password service dapat dikelola/dirotasi oleh domain dan dibatasi ke host yang berhak mengambil managed password. Dalam assessment, catat account type, privilege, SPN ownership, password lifecycle, supported encryption, dan dependency blast radius sebelum menilai risk.

Account pattern	Review focus
Human-style service user	password lifecycle, interactive logon, group privilege, stale ownership
Computer account	host control, delegation, local-admin relationships
gMSA	which hosts can retrieve managed password + privilege scope + SPNs

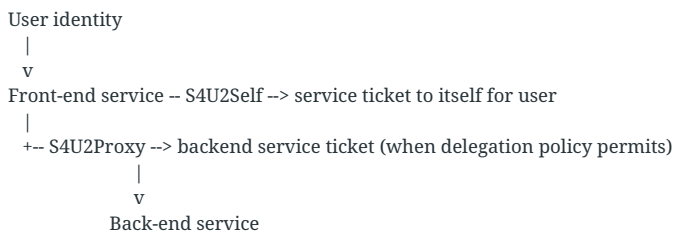
AS-REP pre-auth concept Account yang dikonfigurasi tanpa Kerberos pre-authentication mengurangi bukti awal yang harus diberikan client sebelum KDC merespons. Treat flag tersebut sebagai hardening finding/candidate; jangan melakukan mass account probing di luar authorized lab.

4. Delegation: Unconstrained, Constrained, dan RBCD

Delegation memungkinkan service bertindak atas nama user ketika mengakses service lain. Security question-nya bukan hanya "delegation enabled?" tetapi "siapa boleh mendelegasikan ke mana, siapa mengontrol delegating principal, siapa mengontrol resource object, dan apakah impersonated identity menghasilkan privilege tambahan?"

Mode	Boundary	Assessment question
Unconstrained	broad delegation context	mengapa host/service ini perlu trust seluas itu?
Constrained (KCD)	dibatasi ke backend SPN tertentu	siapa mengontrol delegating account + allowed targets?
Resource-based constrained delegation	resource object menentukan delegator yang dipercaya	siapa punya write/control atas resource object?

S4U2Self dan S4U2Proxy - conceptual map



Kuncinya adalah policy boundary: account mana yang dipercaya, backend SPN mana yang diizinkan, apakah protocol transition relevan, dan siapa yang dapat mengubah delegation attributes/resource ACL. Jangan menyamakan kemampuan protocol dengan authorization aplikasi di backend.

Lab 04 - Read-only delegation inventory

PowerShell> .\labs\delegation-inventory.ps1

Lab 05 - Explain relationship, jangan abuse

python ./labs/delegation-path.py ./labs/sample-delegation.json

Security note Delegation path sering menjadi kombinasi beberapa control relationships. Jangan mengubah msDS-AllowedToDelegateTo, PrincipalsAllowedToDelegateToAccount, atau delegation flags untuk sekadar "membuktikan" finding. Gunakan evidence + deliberately vulnerable lab.

5. ACL Relationships: Control atas Object Lebih Penting dari Nama Group

AD object mempunyai security descriptor dan DACL. Relationship seperti GenericAll, GenericWrite, WriteDacl, WriteOwner, AddMember, atau permission spesifik dapat mengubah siapa yang akhirnya mengontrol object. Red teamer harus membaca edge sebagai capability, bukan sebagai tombol exploit.

Relationship	Capability concept	Validation question
GenericAll	kontrol luas atas object	apakah target object memang membawa path ke objective?
GenericWrite	dapat mengubah subset attribute	attribute mana yang writable dan security-sensitive?
WriteDacl	dapat mengubah DACL	apakah caller boleh memberi rights tambahan?
WriteOwner	dapat mengambil ownership	apakah ownership memberi jalan untuk ubah DACL?
AddMember	dapat menambah member ke group	seberapa sensitif effective privilege group itu?

Edge validation rubric

Question	Evidence yang dicari
Does the edge exist now?	raw ACL/group/session/delegation data + timestamp
Can our principal exercise it?	effective group/token + deny/protection conditions
Does target lead somewhere useful?	next relationship/object privilege
Is it reversible?	original owner/DACL/member/config snapshot
What will defenders see?	directory change events, logon/ticket/process/network artifacts

Lab 06 - Synthetic attack path graph

python ./labs/attack-path-model.py ./labs/sample-acl.json --from-node STUDENT --to-node 'DOMAIN ADMINS'

Expected output hanya menjelaskan relationship chain. Untuk setiap edge tulis: required privilege, object owner, expected change, rollback, dan telemetry. Jangan mengubah ACL di production untuk membuktikan graph.

6. BloodHound: Graph Evidence, Bukan Exploit Button

BloodHound sangat berguna untuk menghubungkan principals, groups, computers, sessions, ACLs, trusts, dan delegation menjadi graph. Tetapi shortest path hanyalah hypothesis generator. Stale session, deny ACL, host offline, hardening, selective authentication, protected users, atau perubahan topology dapat memutus path yang terlihat valid.

Lab 07 - Attack-path triage worksheet

- Pilih satu path dari synthetic graph atau BloodHound CE di GOAD/MINILAB.
- Untuk setiap edge tulis evidence source, required privilege, target object, expected impact, dan uncertainty.
- Beri label edge: confirmed, likely, stale/unknown, atau not-applicable.
- Jangan menjalankan abuse action sebelum semua precondition dan scope gate terpenuhi.

Think like an operator Path yang lebih pendek belum tentu lebih aman atau lebih reliable. Pilih path berdasarkan evidence quality, blast radius, detectability, reversibility, dan Rules of Engagement.

Evidence-quality scoring untuk graph triage

Level	Meaning
A - confirmed	raw current evidence + principal context + target state verified
B - strong	current relationship verified; one operational precondition remains
C - candidate	collector/synthetic edge present but freshness/effective control unknown
D - stale/invalid	relationship no longer exists or policy blocks path

7. Trusts dan Cross-Domain Attack Paths

AD trusts menentukan authentication path antar-domain/forest. Direction, transitivity, trust type, selective authentication, dan SID filtering memengaruhi apa yang mungkin dilakukan. Forest adalah security boundary penting; forest trust tidak otomatis membuat semua privilege menyeberang.

One-way example:

ACCOUNT domain A → RESOURCE domain B

Authentication path allowed only if trust direction supports it, then resource B still performs authorization.

Forest trust: transitive across the two participating forests, but it does not implicitly create trust to a third forest.

Lab 08 - Read-only trust inventory

PowerShell> .\labs\trust-inventory.ps1

Lab 09 - Synthetic trust reasoning

python ./labs/trust-path.py ./labs/sample-trust.json

- Direction menjawab arah authentication path, bukan otomatis arah privilege escalation.
- Transitive trust memperluas namespace yang dapat di-resolve/authenticate, tetapi resource authorization tetap harus lolos.
- Selective authentication dan SID filtering adalah control yang harus dicatat ketika menilai cross-domain hypothesis.

8. AD CS: Certificate Identity sebagai Attack-Path Surface

Active Directory Certificate Services (AD CS) menghubungkan PKI dengan AD. Enterprise CA menggunakan certificate templates yang tersimpan di AD. Dari perspektif security assessment, fokus utamanya: siapa boleh enroll, subject/identity berasal dari mana, ECU apa yang diizinkan, apakah approval/signature diperlukan, dan apakah certificate dapat digunakan untuk authentication.

Template property	Review question	Risk signal
Enrollment rights	siapa boleh enroll?	broad low-priv enrollment
Subject/SAN control	siapa menentukan identity pada certificate?	requester dapat memasukkan identity sensitif
ECU	certificate dipakai untuk apa?	client authentication / smartcard-like auth
Manager approval	ada human gate?	tidak ada approval pada template sensitif
Authorized signatures	butuh enrollment agent/signature?	tidak ada signature requirement

Certificate identity flow

Requester → Certificate Template policy → Enterprise CA → Certificate

```

|           |           |           |
|           | + rights / name / ECU + issuance + may later be used
|           | + authenticated identity           for TLS or AD auth

```

Risk muncul dari kombinasi controls, bukan satu flag. Contoh: broad enrollment + requester-controlled subject/SAN + authentication-capable ECU + tanpa approval/signature gate adalah kombinasi yang harus diprioritaskan untuk review. Template ownership/DACL dan CA publication juga masuk attack-path reasoning.

Lab 10 - Read-only AD CS inventory

PowerShell> .\labs\adcs-inventory.ps1
hasil: 06-adcs/cas.csv dan templates.csv

Important Risky template combination adalah hypothesis, bukan license untuk meminta certificate sebagai identity lain. Controlled issuance/abuse hanya di dedicated AD CS training lab yang memang menyediakan skenario tersebut.

9. Controlled Validation Gate

Sebelum mengubah object, meminta ticket khusus, melakukan certificate enrollment, atau mengeksekusi path, isi gate berikut. Bila satu jawaban belum jelas, kembali ke enumeration.

Gate	Pertanyaan
Authorization	Apakah teknik ini explicitly permitted oleh RoE?
Precondition	Apakah privilege/relationship sudah dikonfirmasi, bukan hanya diasumsikan?
Blast radius	Apakah perubahan dapat memengaruhi user/service lain?
Rollback	Bagaimana mengembalikan ACL, delegation, certificate, group, atau service state?
Evidence	Apa minimum proof yang cukup tanpa menambah impact?
Telemetry	Log/event/process/network artifact apa yang kemungkinan muncul?

Lab 11 - Finding hypothesis note

```
python ./labs/finding-note.py module20-ad-paths/09-findings/path-01.md \
--title 'Delegation path hypothesis' \
--evidence 'Read-only inventory shows delegating principal and backend target.' \
--assumptions 'Caller must control the delegating principal; backend authorization remains required.' \
--impact 'Potential impersonation path if all preconditions hold.' \
--remediation 'Remove unnecessary delegation and reduce control over service/resource objects.'
```

10. Detection-Aware Kerberos & AD Paths

Red teamer yang bagus memahami jejak yang dibuat workflow-nya. Windows Security auditing dapat mencatat ticket activity pada DC dan perubahan directory pada object tertentu. AD CS juga mempunyai audit events bila auditing diaktifkan.

Event / source	Makna umum	Correlation idea
4768	TGT requested	principal, source, encryption type, result
4769	Kerberos service ticket requested	service/SPN, account, encryption type
4771	Kerberos pre-authentication failed	principal + source + failure pattern
5136	Directory object modified	ACL/delegation/template object changes
4886 / 4887	certificate request received / issued	requester, template, CA, subject

Volume saja tidak cukup. Banyak 4769 bisa normal pada service-heavy environment. Detection yang baik menggabungkan baseline, service name, account type, encryption, source host, privilege context, dan perubahan relationship yang terjadi sebelum/ sesudah activity.

Hardening / remediation map

Area	Defensive direction
Service identities	managed rotation/gMSA where appropriate, least privilege, disable interactive use when unnecessary
Kerberos crypto	prefer supported modern encryption; retire legacy dependencies systematically
Delegation	remove unused delegation, constrain targets, protect sensitive principals/resources
ACLs	remove unnecessary write/control edges; tier administrative principals
Trusts	use selective authentication/SID filtering where appropriate; minimize cross-boundary admin paths
AD CS	least-privilege enrollment, secure subject rules/EKU, approval/signature for sensitive templates, monitor CA

11. Capstone - Build 3 Attack-Path Hypotheses

Gunakan GOAD/MINILAB yang terisolasi atau synthetic datasets module ini. Objective capstone bukan mendapatkan Domain Admin, tetapi menghasilkan tiga path hypothesis yang bisa diaudit.

- Path A: service identity / SPN related.
- Path B: delegation atau ACL relationship.

- Path C: trust atau AD CS related.

Untuk setiap path, deliverable wajib:

- Start principal dan target objective.
- Relationship chain lengkap beserta evidence source.
- Required privileges / preconditions per edge.
- What could invalidate the path.
- Minimum-impact validation plan + rollback.
- Likely telemetry dan detection opportunities.
- Remediation yang menghilangkan root cause, bukan hanya block tool.

Lab 12 - Evidence manifest & closure

```
./labs/evidence-manifest.sh module20-ad-paths
sha256sum -c module20-ad-paths/08-evidence/evidence-manifest.sha256
```

12. Compact Cheat Sheet

Area	Read-only question / command
Ticket cache	klist
SPNs	Get-ADUser -LDAPFilter '(servicePrincipalName=*)' ...
Delegation	TrustedForDelegation / msDS-AllowedToDelegateTo / PrincipalsAllowedToDelegateToAccount
ACL	Who controls this object, attribute, DACL, or owner?
Trust	Get-ADTrust -Filter *
AD CS	Inventory enterprise CAs + templates + EKU/name/enrollment flags
Graph	Path = relationship hypothesis; validate every edge
Evidence	Timestamp + raw export + notes + SHA-256 + cleanup status

References

[Microsoft Learn - Kerberos authentication overview](#)
[Microsoft Learn - Service principal names](#)
[Microsoft Learn - Kerberos constrained delegation overview](#)
[Microsoft Learn - Active Directory trusts / key AD DS terms](#)
[Microsoft Learn - Certificate template concepts](#)
[Microsoft Learn - Events to monitor \(4768/4769/4771\)](#)
[SpecterOps BloodHound documentation](#)
[Orange Cyberdefense GOAD](#)

Knowledge Check

#	Question
1	Apa perbedaan TGT dan service ticket dalam Kerberos?
2	Kenapa SPN adalah mapping identity/service, bukan vulnerability dengan sendirinya?
3	Apa perbedaan security boundary unconstrained, constrained, dan RBCD?
4	Kenapa GenericWrite harus dianalisis per attribute/object, bukan dianggap setara GenericAll?
5	Apa tiga alasan BloodHound shortest path bisa stale atau not-applicable?
6	Bagaimana direction dan selective authentication mengubah analisis trust?

Common mistakes & troubleshooting

Symptom	Check first
klist hampir kosong	pastikan session domain-authenticated dan service domain memang sudah diakses
SPN inventory kosong	cek ActiveDirectory module, domain connectivity, dan search scope
BloodHound path tidak bisa direproduce	cek session freshness, host state, deny ACL, protected users, trust controls
AD CS inventory kosong	pastikan enterprise CA/template memang ada dan configurationNamingContext terbaca

Completion checklist

- 12 guided labs selesai dan evidence tersimpan di workspace dengan permission terbatas.
- Minimal tiga attack-path hypotheses mempunyai evidence, precondition, uncertainty, telemetry, rollback, dan remediation.
- Tidak ada domain production yang dimodifikasi untuk sekadar membuktikan graph relationship.
- Evidence manifest SHA-256 berhasil diverifikasi sebelum module ditutup.

Self-review answer cues

- TGT dipakai untuk meminta service ticket; service ticket ditujukan ke SPN/service tertentu.
- SPN memetakan service instance ke sign-in account; risk baru muncul dari lifecycle, crypto, privilege, dan relationship lain.
- Delegation harus dibaca sebagai policy boundary: siapa boleh bertindak untuk siapa dan ke backend mana.
- GenericWrite tidak selalu memberi capability yang sama; attribute yang writable menentukan impact.
- BloodHound path dapat stale karena session, ACL, topology, host state, trust controls, atau protection mechanisms berubah.
- Trust memperluas authentication path; authorization resource dan boundary controls tetap menentukan access akhir.

Attack-path worksheet template

Step	Principal	Relationship	Target	Evidence / uncertainty
1	_____	_____	_____	_____
2	_____	_____	_____	_____
3	_____	_____	_____	_____
4	_____	_____	_____	_____

Worked example - hypothesis, bukan exploit plan

Step	Observation	Interpretation
1	STUDENT MemberOf HELPDESK	principal inherits helpdesk group rights
2	HELPDESK GenericWrite SVC_APP	verify which service-account attributes are actually writable
3	SVC_APP controls APP01 service context	confirm host/service ownership and effective authorization
4	APP01 has privileged reach to FILE01	network reachability + local/service authorization still required

Kesimpulan yang benar: ada candidate relationship chain yang layak ditriage. Kesimpulan yang belum boleh dibuat: "STUDENT pasti bisa menjadi Domain Admin". Gap antar-edge harus divalidasi satu per satu, dan minimum-impact proof harus dipilih berdasarkan RoE.

Handoff to Module 21 Simpan tiga path hypothesis terbaik. Module 21 (Pivoting & Lateral Movement) akan memakai konsep identity, authorization, network reachability, segmentation, dan session evidence untuk memahami bagaimana akses berpindah antar-host/subnet tanpa kehilangan scope discipline.